



Lab 15 — Conduct a Full AI Security Risk Assessment

Topic 04: Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Objective: Implement a structured AI risk assessment producing rated risks, mapped controls, residual risk and assigned treatments with owners.

Goal: This is the assessment that a regulator, an auditor or a board will ask to see. You will run a complete structured risk assessment on NovaAssist, combining everything from the previous fourteen labs into a single defensible document with rated, owned and treated risks.

What you'll build: A complete AI security risk assessment: 12 rated risks with likelihood, impact, existing controls, residual rating, treatment decision, owner and target date.

Tools and data: Risk assessment template (risk-assessment-template.csv), 5x5 rating matrix, all prior lab outputs

Data files in this lab

- data/rating-matrix.md
- data/risk-assessment-template.csv
- data/risk-source-checklist.md

Step-by-step

1. Open risk-assessment-template.csv and the rating matrix in labs/lab-15-risk-assessment/data/. Confirm the scoring: likelihood 1-5, impact 1-5, risk score as the product, with bands Low 1-6, Medium 8-12, High 15-25.
2. Define the assessment scope precisely: the system, its version, its data, its tools, its users and the boundary of the assessment. An unbounded scope produces an unusable assessment.
3. Identify twelve risks by drawing on your earlier work: the trifecta exposure from Lab 3, the NIST GenAI risks, the OWASP agentic risks from Lab 13, the data risks from Lab 9 and the PDPA risks from Lab 8.
4. Write each risk as a proper risk statement in the form: cause leads to event leads to consequence. 'Prompt injection' is not a risk statement; 'untrusted e-mail content injects instructions, causing the agent to send account data externally, resulting in a PDPA breach' is.

5. Rate inherent likelihood and impact for each risk before controls, using the matrix. Record the reasoning for any rating of 4 or 5 — those are the ratings that will be challenged.
6. Map the existing and planned controls from Labs 11 and 13 to each risk. A risk with no mapped control keeps its inherent rating; do not credit controls you have not specified.
7. Rate residual likelihood and impact after controls, and compute the residual score. Be honest: guardrails reduce likelihood, they rarely reduce impact.
8. Assign a treatment to every risk: treat, tolerate, transfer or terminate. Any residual High risk must be treated or escalated for formal acceptance by the executive owner — record which.
9. Assign an owner and a target date to every treatment action. An unowned treatment is a wish; check that every owner is a role that exists in your Lab 7 operating model.
10. Write the two-paragraph executive summary: the overall risk position, the three risks that matter most, and your clear recommendation on whether NovaAssist should go live and under what conditions.

Test it

All twelve risks are written as cause-event-consequence statements, every residual High risk has either a treatment plan or a recorded acceptance by a named executive, and every treatment has an owner who exists in your operating model.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.